

RAPPORT FINAL D'ASSURANCE QUALITÉ LOGICIELLE — BIPROJECT

Projet : BiProject (Architecture .NET & Angular)
Auteurs : Youssef Chaari & Mohamed Aziz Zouari
Date : 15 Mars 2026
Version : 4.1

1. Introduction et Périmètre de l'Audit

Ce rapport présente les conclusions de l'audit de qualité logicielle réalisé sur l'application **BiProject**. Ce système est une plateforme intégrée de gestion commerciale et de Business Intelligence (BI), conçue pour faciliter le suivi des ventes et l'analyse stratégique des données pour les entreprises.

L'objectif principal de notre mission a été de certifier la fiabilité du système à travers une campagne de tests rigoureuse. L'audit a couvert l'ensemble de la pile technologique :

- Le **Backend REST** sous ASP.NET Core 8 (C#).
- Le **Frontend SPA** sous Angular.
- Le **Cloisonnement sécuritaire** des données commerciales.

2. Conformité au Guideline du Projet

Le présent audit est strictement aligné sur les exigences académiques du cahier des charges.

Exigence Guideline	Mise en Œuvre et Preuve Factuelle
Tests Statiques	Inspections manuelles et revues de code (AN-01 à AN-03).
Tests Fonctionnels	Validation des flux Auth, Inscription, Catalogue et Commandes.
Tests Non-Fonctionnels	Focus majeur sur la sécurité (Contrôle d'accès et vulnérabilités IDOR).
Niveaux de Test	Couverture des trois niveaux : Unitaire, Intégration et Système (E2E).
Techniques de Test	Alternance entre techniques de Boîte Blanche et de Boîte Noire.
Automatisation	Suites automatisées pérennes (xUnit, Selenium avec POM, Robot Framework).
Traçabilité	Mapping exhaustif Exigences -> Tests -> Résultats.

3. Stratégie et Méthodologie de Test

3.1 Niveaux de Test et Objectifs

Notre campagne s'est articulée autour de trois paliers fondamentaux :

1. **Tests Unitaires (Backend)** : Validation de la logique métier isolée via xUnit et bases In-Memory.

- 2. **Tests d'Intégration (Backend)** : Vérification des contrats API et de la persistance réelle via `WebApplicationFactory`.
- 3. **Tests Système (E2E)** : Simulation des flux utilisateurs complets via Selenium WebDriver (pattern POM) et Robot Framework pour la validation croisée des scénarios critiques.

3.2 Justification du Test Non-Fonctionnel

Nous avons choisi la **Sécurité informatique** (Access Control) comme axe majeur. Dans une application BI, l'intégrité des rapports de vente est critique. Une faille de type IDOR (*Insecure Direct Object Reference*) compromettrait la confidentialité stratégique des clients.

4. Activités de Tests Statiques

4.1 Registre des Anomalies Statiques Détectées

ID	Localisation	Anomalie	Gravité	Recommandation
AN-01	OrderController	IDOR : Manque de vérification de propriété sur les commandes.	Critique	Valider le <code>UserId</code> via le Token JWT sécurisé.
AN-02	DTOs/OrderCreate	Trust Boundary Violation : <code>UserId</code> falsifiable par le client.	Majeure	Utiliser l'identité du serveur uniquement.
AN-03	AuthService	Absence de Logging d'audit sur les échecs de connexion.	Mineure	Injecter <code>ILogger</code> pour tracer les échecs suspects.

5. Catalogue Récapitulatif des Cas de Test

ID	Titre du Cas de Test	Niveau	Type	Technique	Outil / Fichier	Statut
CT-01	Login réussi (User)	Système	Fonc.	B. Noire	Selenium / POM	☒ Pass
CT-02	Rejet mot de passe incorrect	Système	Fonc.	B. Noire	Selenium / POM	☒ Pass
CT-03	Blocage AuthGuard Angular	Système	Sécu.	B. Noire	Selenium / POM	☒ Pass
CT-04	Génération technique Token	Unitaire	Fonc.	B. Blanche	AuthServiceTests	☒ Pass
CT-05	Levée d'exception Auth	Unitaire	Fonc.	B. Blanche	AuthServiceTests	☒ Pass
CT-06	Protection énumération comptes	Unitaire	Fonc.	B. Blanche	AuthServiceTests	☒ Pass
CT-07	Anonyme -> GET /orders	Intégra.	Sécu.	B. Noire	OrderIntegration	☒ Pass

ID	Titre du Cas de Test	Niveau	Type	Technique	Outil / Fichier	Statut
CT-08	Anonyme -> POST /orders	Intégra.	Sécu.	B. Noire	OrderIntegration	☒ Pass
CT-09	Anonyme -> POST /products	Intégra.	Sécu.	B. Noire	OrderIntegration	☒ Pass
CT-10	Inscription réussie (E2E)	Système	Fonc.	B. Noire	Selenium / POM	☒ Pass
CT-11	Détection doublon email	Système	Fonc.	B. Noire	Selenium / POM	☒ Pass
CT-12	Affichage grille produits	Système	Fonc.	B. Noire	Selenium / POM	☒ Pass
CT-13	API détail produit	Intégra.	Fonc.	B. Noire	ProductIntegration	☒ Pass
CT-14	Rôle User -> Create Product	Intégra.	Sécu.	B. Noire	SecurityIntegration	☒ Pass
CT-15	Rôle Admin -> Create Product	Intégra.	Fonc.	B. Noire	AdminIntegration	☒ Pass
CT-16	Filtrage historique personnel	Intégra.	Fonc.	B. Noire	OrderIntegration	☒ Pass
CT-17	Validation flux Checkout	Intégra.	Fonc.	B. Noire	OrderIntegration	☒ Pass
CT-18	Isolation IDOR (Ordre fixe)	Intégra.	Sécu.	B. Noire	SecurityIntegration	☒ Fail
CT-19	Accès RBAC Analytics	Intégra.	Sécu.	B. Noire	SecurityIntegration	☒ Fail
CT-20	Vérification vulnérabilité IDOR	Intégra.	Sécu.	B. Noire	VulnerabilityTests	☒ Fail
CT-21	Connexion réussie (Robot)	Système	Fonc.	B. Noire	Robot Framework	☒ Pass
CT-22	Consultation catalogue (Robot)	Système	Fonc.	B. Noire	Robot Framework	☒ Pass

6. Rapport d'Exécution et Bilan Dynamique

6.1 Synthèse de l'Exécution

- **Total des tests exécutés** : 22
- **Pass** : 19 (86.4%)

- **Fail** : 3 (13.6%) — *Échecs révélateurs de vulnérabilités.*

6.2 Résultats par Couche Logicielle

- **Tests Unitaires / Intégration (C#)** : 14 tests, 11 ☒ Pass / 3 ☒ Fail.
- **Tests Système (Selenium/POM)** : 6 tests, 6 ☒ Pass (100%).
- **Tests Système (Robot Framework)** : 2 tests, 2 ☒ Pass (100%).

7. Analyse Détaillée des Échecs Révélateurs

7.1 CT-18 & CT-20 : Défaut de Cloisonnement (IDOR)

- **Objectif** : Vérifier que l'utilisateur A ne peut pas lire une commande de l'utilisateur B.
- **Résultat Réel** : Retour HTTP 200 OK (Accès illégitime autorisé).
- **Impact** : Fuite massive de données clients (Non-conformité RGPD).
- **Recommandation** : Filtrer impérativement par `UserId` dans toutes les requêtes de données individuelles.

7.2 CT-19 : Défaillance RBAC sur Analytics

- **Objectif** : Restreindre les données de BI au rôle Admin.
- **Résultat Réel** : Accès autorisé (200 OK) pour un rôle User.
- **Recommandation** : Appliquer l'attribut `[Authorize(Roles = "Admin")]` sur les contrôleurs de statistiques.

8. Matrice de Traçabilité des Exigences

ID Exigence	Description Métier	CT Associés	Statut Final
REQ-AUTH-01	Authentification JWT sécurisée	CT-01, 04, 05, 06	Qualifiée (✓)
REQ-SEC-01	Protection par défaut de l'API	CT-07, 08, 09, 14	Qualifiée (✓)
REQ-SEC-02	Isolation IDOR des commandes	CT-18, 20	Anomalie (✗)
REQ-ORD-01	Processus de checkout	CT-16, 17	Qualifiée (✓)

9. Déclaration d'Usage de l'Intelligence Artificielle

Conformément aux bonnes pratiques académiques en vigueur, nous déclarons avoir recouru à des outils d'IA générative au cours de ce projet, dans un cadre complémentaire et supervisé.

Usages effectifs :

- Génération de la structure initiale des squelettes de tests (boilerplate xUnit, Selenium).
- Aide à la reformulation et à la mise en forme de certains passages documentaires.
- Assistance au débogage de configurations techniques (setup du `WebApplicationFactory`, `conftest.py`, Robot Framework).

Ce qui a été réalisé par les auteurs : L'ensemble de la **stratégie de test**, la **définition des cas de test**, l'**analyse des résultats**, l'**interprétation des anomalies** (notamment la vulnérabilité IDOR) et les **décisions de correction** ont été conduits exclusivement par Youssef Chaari et Mohamed Aziz Zouari. Chaque résultat a fait l'objet d'une vérification manuelle.

10. Conclusion Finale et Recommandations

L'application **BiProject** présente une maturité fonctionnelle élevée sur ses parcours nominaux (86% de succès). Cependant, la présence de failles critiques de type **IDOR** identifiées par l'audit nécessite des correctifs immédiats. La mise en œuvre d'une pipeline CI/CD automatisant l'ensemble des suites (xUnit, Selenium, Robot) est recommandée pour pérenniser la qualité du système.
